CFGS DESARROLLO DE APLICACIONES MULTIPLATAFORMA · 2.º CURSO · IPE II

VulnFollowUp: Modelo de Negocio y Plan Estratégico

Entorno Regulatorio: Reglamento DORA (UE 2022/2554) **Modelo:** B2B Micro-SaaS **Alcance:** Gestión de Riesgos TIC

1. Contexto Profesional y Modelo Lean Canvas

La entrada en vigor de DORA exige a las entidades financieras fiscalizar rigurosamente la cadena de suministro tecnológica. Las pequeñas y medianas empresas proveedoras de servicios TIC pierden oportunidades comerciales si no demuestran control estricto sobre sus activos, gestión formal de vulnerabilidades y trazabilidad de proveedores. **VulnFollowUp** nace para cubrir este vacío mediante una solución ágil y asequible.

Bloque 1: Problema del Mercado y Clientes Objetivo

Problema central: Las pymes TIC gestionan vulnerabilidades mediante hojas de cálculo desconectadas o gestores genéricos de tareas. Carecen de cálculo formal CVSS, ciclo de vida auditable e informes que satisfagan a los departamentos de cumplimiento bancario. Las suites GRC corporativas son inasumibles en coste y complejidad técnica.
Clientes objetivo: Pequeñas empresas de desarrollo de software, consultoras técnicas, empresas de hosting/cloud e integradores que prestan servicios o licitan ante bancos, entidades aseguradoras y fintechs.

Bloque 2: Propuesta de Valor y Solución Técnica

Propuesta de valor: «Gobernanza de vulnerabilidades y supervisión de proveedores TIC lista para auditorías DORA, sin la complejidad ni los costes prohibitivos de las suites corporativas».
Solución: Plataforma integral cliente-servidor que estandariza la severidad con CVSS Base v3.1/v4.0, orquesta el ciclo de remediación con evidencias verificables y vincula automáticamente cada CVE detectado con el activo crítico y el contrato del proveedor TIC responsable.

Bloque 3: Estructura Financiera, Canales y Ventaja Competitiva

Canales de comercialización: Venta directa B2B a pymes tecnológicas, alianzas estratégicas con consultoras de auditoría/cumplimiento normativo y posicionamiento orgánico en comunidades de ciberseguridad.
Flujo de ingresos: Suscripción mensual/anual SaaS categorizada por número de activos monitorizados y proveedores registrados, complementada con servicios puntuales de soporte en auditorías.
Ventaja diferencial: Unión simbiótica entre el dato técnico de vulnerabilidad y la trazabilidad de contratos de terceros requerida contractualmente por las entidades financieras.

2. Benchmark Competitivo y Posicionamiento

Para determinar la viabilidad comercial de VulnFollowUp frente a la oferta existente, se evalúan tres plataformas representativas de distintos enfoques de seguridad y cumplimiento:

Plataforma	Enfoque Operativo	Proveedores TIC (DORA)	Coste Estimado	Idoneidad Pyme
Tenable VM ESCÁNER RED	Detección activa por red de vulnerabilidades e infraestructura corporativa.	Nula. No contempla contratos, criticidad ni SLAs de proveedores TIC.	Muy elevado (>3.000 €/año por bloque de IPs).	BAJA Exceso de coste y complejidad.
OWASP DefectDojo DEVSECOPS	Agregación y triaje de hallazgos procedentes de herramientas SAST/DAST.	Inexistente. Enfoque exclusivo en código fuente y repositorios.	Licencia libre (Open Source), pero alto coste en hosting y mantenimiento.	MEDIA Requiere perfiles AppSec avanzados.
OneTrust TPRM SUITE GRC	Evaluación de riesgos de terceros mediante cuestionarios legales y normativos.	Muy alta a nivel administrativo, pero aislada del plano técnico.	Prohibitivo (>15.000 €/año en planes base corporativos).	INVIABLE Reservada a gran banca y corporaciones.
VulnFollowUp NUESTRA SOLUCIÓN	**Gestión defensiva, validación CVSS Base y seguimiento de remediaciones.**	**Integrada nativamente: activos, contratos y cuadro de mando de riesgo.**	**Muy asequible (SaaS escalable desde 29 €/mes).**	ÓPTIMA **Diseño ajustado a la realidad de la pyme.**

La Ventaja Competitiva Clave (Unfair Advantage)

> **El Puente entre el Dato Técnico y la Exigencia Regulatoria**
>
> VulnFollowUp elimina la desconexión existente en el mercado: las herramientas de escaneo técnico ignoran las cláusulas de proveedores TIC de DORA, mientras que el software GRC carece de control sobre el ciclo de vida de los CVEs. Nuestra plataforma proporciona el informe exacto que los auditores bancarios demandan, sin fricción operativa.

Estructura de Monetización SaaS

PLAN STARTER
29 €/mes
Hasta 15 activos y 5 proveedores TIC. Ideal para microempresas que inician proyectos financieros.

PLAN BUSINESS
79 €/mes
Hasta 60 activos, 20 proveedores, exportación de informes para auditorías y app móvil completa.

PLAN ENTERPRISE
199 €/mes
Activos ilimitados, reglas de negocio personalizadas y soporte prioritario en auditorías DORA.

3. Matriz DAFO de VulnFollowUp

El análisis DAFO sintetiza el diagnóstico interno del producto y las condiciones del mercado tecnológico europeo, fundamentando las decisiones de diseño y explotación comercial:

FORTALEZAS (Internas) F

- **Alineación directa con DORA:** Módulo nativo de proveedores TIC y contratos vinculado a los activos técnicos.
- **Estandarización rigurosa:** Validación automatizada de vectores y puntuación CVSS Base (v3.1 y v4.0).
- **Arquitectura multiplataforma:** Backend REST común con cliente Web/Desktop y app Android conectada.
- **Trazabilidad y control:** Perfiles de acceso (ADMIN, ANALYST, VIEWER) y evidencias auditables de remediación.
- **Baja curva de adopción:** Puesta en marcha inmediata sin configuraciones complejas de red.

DEBILIDADES (Internas) D

- **Sin escaneo activo propio:** Depende de cargas de datos sintéticos, públicos o entrada manual por analistas.
- **Marca y tracción incipientes:** Producto nuevo sin cartera previa de clientes en el sector bancario.
- **Capacidad humana limitada:** Estructura técnica reducida que no puede ofrecer soporte ininterrumpido 24/7.
- **Ausencia de integraciones iniciales:** Sin conectores directos a sistemas corporativos de tickets (Jira, ServiceNow).

OPORTUNIDADES (Externas) O

- **Obligatoriedad legal de DORA:** Las entidades financieras exigen evidencias de seguridad a sus proveedores.
- **Nicho de pymes desatendido:** Ausencia de herramientas específicas a precios compatibles con presupuestos de pymes.
- **Extensibilidad a NIS2:** Marco regulatorio extensible a otros sectores estratégicos esenciales.
- **Automatización mediante APIs:** Potencial de conexión con fuentes oficiales abiertas (NVD, NIST, MITRE).

AMENAZAS (Externas) A

- **Resistencia cultural:** Persistencia en el uso de herramientas ofimáticas gratuitas (Excel) pese a su falta de seguridad.
- **Reacción de suites GRC:** Posible lanzamiento de planes simplificados "low-cost" por parte de competidores consolidados.
- **Exigencias de certificación:** Requisito bancario de sellos como ISO 27001 o SOC 2 para validar informes.
- **Evolución normativa continua:** Modificaciones técnicas en estándares CVSS o directrices europeas de supervisión.

Síntesis de Posición Estratégica

VulnFollowUp se sitúa en una posición competitiva privilegiada al actuar como acelerador de cumplimiento para proveedores TIC. La falta de escaneo propio no representa un obstáculo insalvable, ya que la mayor necesidad de las pymes no radica en descubrir fallos, sino en priorizarlos, remediarlos formalmente y demostrar su control ante auditores bancarios.

4. Plan Estratégico CAME y Viabilidad Económica

A partir del diagnóstico DAFO, se articulan las líneas de actuación estratégica para maximizar las fortalezas de VulnFollowUp y neutralizar sus riesgos:

Estrategia	Enfoque Operativo	Línea de Acción para VulnFollowUp
Corregir (D) REORIENTACIÓN	Paliar la ausencia de escaneo activo de red.	Integrar en la hoja de ruta la importación automática de vulnerabilidades desde APIs de registros públicos (NVD del NIST y MITRE CVE), minimizando la carga manual.
Afrontar (A) SUPERVIVENCIA	Vencer la inercia del uso de hojas de cálculo.	Potenciar la generación de informes ejecutivos en PDF/CSV listos para presentar al auditor bancario, demostrando el ahorro de semanas de trabajo manual.
Mantener (F) DEFENSIVA	Consolidar el valor de la supervisión de proveedores.	Perfeccionar las reglas de negocio de DORA en backend (bloqueo automático ante incidencias críticas) y la usabilidad de la interfaz en movilidad.
Explotar (O) OFENSIVA	Capitalizar la urgencia regulatoria europea.	Posicionar el servicio como el «Kit de Homologación DORA» para pymes tecnológicas mediante marketing de contenidos enfocado a directores de TI y CISOs.

Presupuesto Inicial y Viabilidad Financiera

> **Estimación de Costes y Punto de Equilibrio (Break-Even)**
> El desarrollo del núcleo técnico demanda aproximadamente 50 horas de trabajo en equipo. Con un coste hora estimado de 35 €/h y unos costes de infraestructura en la nube (Docker, Nginx y PostgreSQL gestionado) de 60 €/mes, la inversión inicial se sitúa en 1.750 €. Con el *Plan Business* a 79 €/mes, el punto de equilibrio operativo se alcanza con tan solo **12 clientes activos**, garantizando una alta viabilidad económica.

Forma Jurídica y Conclusiones del Módulo IPE II

Para la explotación del servicio se propone la constitución de una **Sociedad de Responsabilidad Limitada Unipersonal (S.L.U.)** o microempresa de base tecnológica, limitando la responsabilidad patrimonial frente a clientes bancarios. VulnFollowUp demuestra ser técnicamente ejecutable, comercialmente rentable y rigurosamente alineada con las demandas reales del mercado laboral en desarrollo multiplataforma.